

# Catalogs of the analysis instruments

Supplementary material of the dissertation

*Combining STPA, STRIDE, and LINDDUN PRO to derive cybersecurity and data privacy requirements with LGPD traceability: a smart tourism use case*

Dênis Júnio Zeferino

Instituto Tecnológico de Aeronáutica (ITA), Graduate Program of Mission-Critical Computing

Advisor: Prof. Dr. Celso Massaki Hirata

2026

# Contents

|          |                                                                     |           |
|----------|---------------------------------------------------------------------|-----------|
| <b>A</b> | <b>Causal scenarios of Step 4</b>                                   | <b>2</b>  |
| <b>B</b> | <b>STRIDE threat groups, controls, and threat records of Step 6</b> | <b>4</b>  |
| <b>C</b> | <b>LINDDUN PRO threat groups, threats, and controls of Step 7</b>   | <b>10</b> |

These catalogs reproduce, in English, the complete lists registered in the instruments of the analysis (workbooks in Portuguese, in the same repository): the 26 causal scenarios of Step 4, the 12 STRIDE threat groups, the 14 cybersecurity controls, and the 98 threat records of Step 6, and the 24 LINDDUN PRO threat groups, the 107 data privacy threats, and the 71 data privacy controls of Step 7. Chapter, section, and table numbers mentioned in the text refer to the dissertation.

# Catalog A

## Causal scenarios of Step 4

This catalog presents the 26 causal scenarios developed in Step 4 of the STPA analysis of Chapter 5 of the dissertation, registered in AppSTPA on 25 representative HCAs. For each scenario, Table A.1 gives the context that triggers it, the main HCA, the set of HCAs explained by the scenario, including the main HCA, and the hazards registered for the scenario in the instrument of the analysis. The hazards column is not always the union of the hazards of the HCAs explained, as Section 5.5 of the dissertation notes. The codes TUR, SMA, BAC, OPE, and GER identify the Tourist, the Smartphone application, the Back-end, the Operations Team, and Company Management, and the numbers of the HCAs are the ones generated by AppSTPA.

Table A.1: Causal scenarios of Step 4, with the main HCA, the HCAs explained, and the hazards.

| Scenario | Context                                                                         | Main HCA | HCAs explained                                 | ex- | Hazards  |
|----------|---------------------------------------------------------------------------------|----------|------------------------------------------------|-----|----------|
| C-TUR-01 | Terms pending or rejected before the consents and the personal data             | HCA-50   | HCA-50 to HCA-55                               |     | H-1      |
| C-TUR-02 | Use of the service before the acceptance of the terms                           | HCA-56   | HCA-56, HCA-57                                 |     | H-1      |
| C-TUR-03 | Revocations, blocking, and deletion requested while the intention to use is Yes | HCA-60   | HCA-60, HCA-63, HCA-65, HCA-66, HCA-67         |     | H-7      |
| C-TUR-04 | Acceptance of the terms in the wrong order                                      | HCA-68   | HCA-68                                         |     | H-1, H-6 |
| C-TUR-05 | Insufficient feedback on the status of the terms                                | HCA-64   | HCA-64, HCA-69                                 |     | H-7      |
| C-TUR-06 | Absence of a clear panel for the revocation of consents                         | HCA-59   | HCA-59, HCA-62                                 |     | H-5      |
| C-TUR-07 | Consent not requested at the adequate moment                                    | HCA-58   | HCA-58, HCA-61                                 |     | H-7      |
| C-TUR-08 | Low regulatory awareness of the data subject                                    | HCA-64   | HCA-58, HCA-59, HCA-61, HCA-62, HCA-64, HCA-69 |     | H-7      |
| C-SMA-01 | Terms acceptance status Rejected                                                | HCA-30   | HCA-30, HCA-31, HCA-34, HCA-37                 |     | H-1, H-5 |

*Continues on the next page*

Table A.1 (continued)

| Scenario | Context                                                                 | Main HCA | HCAs explained                         | ex-          | Hazards                 |
|----------|-------------------------------------------------------------------------|----------|----------------------------------------|--------------|-------------------------|
| C-SMA-02 | Outdated version of the consent terms                                   | HCA-33   | HCA-33, HCA-35, HCA-40                 | HCA-38,      | H-1, H-5, H-6           |
| C-SMA-03 | Reauthentication request pending                                        | HCA-36   | HCA-36, HCA-39, HCA-43, HCA-46, HCA-48 | HCA-41, HCA- | H-2, H-5, H-6           |
| C-SMA-04 | Personal data status Legally rejected by the Back-end                   | HCA-42   | HCA-42, HCA-44                         |              | H-1, H-3, H-7           |
| C-SMA-05 | Acceptance of the terms recorded in the wrong order                     | HCA-32   | HCA-32                                 |              | H-1, H-6                |
| C-SMA-06 | Itinerary request not issued with the prerequisites satisfied           | HCA-45   | HCA-45                                 |              | H-1, H-7                |
| C-SMA-07 | Technical failure in the critical transactions of rights and acceptance | HCA-47   | HCA-47, HCA-49                         |              | H-1, H-4, H-6, H-7      |
| C-BAC-01 | External channel available, but the request is not issued               | HCA-1    | HCA-1, HCA-4                           |              | H-7                     |
| C-BAC-02 | External channel unavailable or degraded, but the request is maintained | HCA-2    | HCA-2, HCA-3, HCA-5, HCA-6             |              | H-7                     |
| C-BAC-03 | Data of the tourist attraction absent                                   | HCA-7    | HCA-7                                  |              | H-7                     |
| C-BAC-04 | Attraction restricted, overcrowded, or with local restrictions          | HCA-8    | HCA-8 to HCA-11                        |              | H-7                     |
| C-OPE-01 | Logs unavailable or operation inoperative                               | HCA-12   | HCA-12, HCA-19                         |              | H-2, H-6                |
| C-OPE-02 | Critical alerts received                                                | HCA-13   | HCA-13, HCA-21, HCA-22                 |              | H-2, H-6                |
| C-OPE-03 | Control execution status Failed                                         | HCA-14   | HCA-14, HCA-16, HCA-18                 | HCA-17,      | H-1, H-2, H-3, H-5, H-6 |
| C-OPE-04 | LGPD rights requests overdue                                            | HCA-15   | HCA-15, HCA-20                         |              | H-3, H-4                |
| C-GER-01 | Compliance reports Non-compliant                                        | HCA-23   | HCA-23, HCA-26, HCA-28                 |              | H-1, H-6                |
| C-GER-02 | Severe incident escalation received                                     | HCA-24   | HCA-24, HCA-25                         |              | H-2, H-6                |
| C-GER-03 | LGPD request status Overdue                                             | HCA-27   | HCA-27, HCA-29                         |              | H-4, H-7                |

## Catalog B

# STRIDE threat groups, controls, and threat records of Step 6

This catalog registers the complete results of the STRIDE analysis of Step 6, presented in Section 6.2 of the dissertation. Table B.1 presents the 12 threat groups with their threat family, their STRIDE categories, the flows and the number of records consolidated in each group, and the hazards. Table B.2 presents the 14 cybersecurity controls derived from the groups, with their statements and their relation to STPA. In the statements, operator designates a member of the Operations Team, the staff of the controller, and not the data processor of the law. Table B.3 lists the 98 candidate threat records generated by the TMT, with the TMT identifier, the DFD flow of the interaction, the STRIDE category, the title of the record in the tool, the decision of the review, the consolidated group of the applicable records, and the hazards. The records classified as not applicable carry the code of the justification. NA-2 indicates that the communication model of the design does not correspond to the one presupposed by the record, and NA-3 indicates that the record presupposes a delegation or reuse of security context that the design does not have. The four records generated on the interactions labeled Request were assigned to F1 or to F12 according to the entity that they concern.

Table B.1: STRIDE threat groups of Step 6, with the flows, the number of consolidated records, and the hazards.

| Group       | Threat family and STRIDE categories                                                 | Flows (records)                        | Hazards            |
|-------------|-------------------------------------------------------------------------------------|----------------------------------------|--------------------|
| CT-STR-01   | Weak authentication in API and administration flows. Information Disclosure         | F3, F4, F7, F8, F14, F15 (6)           | H-1, H-2, H-6      |
| CT-STR-02   | Replay and tampering of messages in the network flows. Tampering                    | F3, F4, F7, F8, F15 (10)               | H-1, H-2, H-6      |
| CT-STR-03   | Insecure JSON processing. Tampering                                                 | F3, F4, F7, F8, F14, F15 (6)           | H-2                |
| CT-STR-04   | Interruption of flows and unavailability of processes. Denial of Service            | F3, F4, F5, F6, F9, F10, F14, F15 (15) | H-2, H-3, H-4, H-7 |
| CT-STR-05.A | Integrity and non-repudiation of the audit trails. Tampering, Repudiation, Spoofing | F11 (8)                                | H-2, H-6           |
| CT-STR-05.B | Confidentiality and access control of the logs. Information Disclosure              | F11 (3)                                | H-2, H-6           |
| CT-STR-05.C | Availability and resilience of the logs. Denial of Service                          | F11 (3)                                | H-2, H-6           |

*Continues on the next page*

Table B.1 (continued)

| Group     | Threat family and STRIDE categories                                                                           | Flows (records)                    | Hazards            |
|-----------|---------------------------------------------------------------------------------------------------------------|------------------------------------|--------------------|
| CT-STR-06 | Database and persistence threats. All six categories                                                          | F9, F10 (12)                       | H-2, H-3, H-4, H-6 |
| CT-STR-07 | Spoofing and tampering in the SEFD external service. Spoofing, Tampering, Repudiation, Elevation of Privilege | F5, F6 (6)                         | H-2, H-5, H-6, H-7 |
| CT-STR-08 | Privileged operational access and elevation of privilege. Elevation of Privilege                              | F3, F4, F7, F8, F10, F14, F15 (12) | H-2, H-5           |
| CT-STR-09 | Spoofing of human entities in the interface flows. Spoofing, Elevation of Privilege                           | F1, F12 (4)                        | H-1, H-2, H-6      |
| CT-STR-10 | Repudiation of receipt by the processes. Repudiation                                                          | F3, F4, F6, F10, F14, F15 (6)      | H-4, H-6           |

Table B.2: Cybersecurity controls derived from the STRIDE threat groups, with their statements and their relation to STPA.

| Control      | Statement of the control                                                                                                                                         | Relation to STPA |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| CTL-STR-01   | Authenticate data subjects, operators, and services with strong mechanisms before allowing access to sensitive functions or to flows of personal data            | Common to STPA   |
| CTL-STR-02   | Ensure the integrity, the freshness, and the protection against replay of the messages in the application, administration, and internal flows                    | Additional       |
| CTL-STR-03   | Validate strictly the JSON payloads received and issued, rejecting unexpected, malformed, or incompatible structures                                             | Additional       |
| CTL-STR-04.A | Limit the consumption of resources and control the volume, frequency, and duration of the requests in the critical flows                                         | Additional       |
| CTL-STR-04.B | Maintain operational continuity and controlled degradation of the critical flows under failure, overload, or partial unavailability                              | Common to STPA   |
| CTL-STR-05.A | Record authenticated, tamper-resistant audit trails for the processing, security, consent, and operation events                                                  | Common to STPA   |
| CTL-STR-05.B | Protect the logs against unauthorized access and avoid the exposure of personal data or sensitive inferences in the audit trails                                 | Additional       |
| CTL-STR-05.C | Ensure the continuity and the recovery of the log writing under failure, overload, or temporary unavailability of the audit repository                           | Common to STPA   |
| CTL-STR-06   | Protect the persistence of personal data, consents, rights requests, and operational states, with a verifiable transactional confirmation of each critical write | Additional       |

*Continues on the next page*

Table B.2 (continued)

| Control      | Statement of the control                                                                                                                                                                                        | Relation to STPA |
|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| CTL-STR-07   | Authenticate the SEFD, verify the origin and the integrity of its responses, validate their structure and content, and process external data in an isolated context, with correlated records of the exchange    | Additional       |
| CTL-STR-08.A | Apply access control, segregation of duties, and least privilege to data subjects, operators, components, and service accounts in the sensitive and administrative flows                                        | Common to STPA   |
| CTL-STR-08.B | Validate the inputs and isolate the execution contexts, so that adversarial payloads or commands cannot cause improper execution or change the control flow                                                     | Additional       |
| CTL-STR-09   | Require that sensitive actions be performed by an authenticated and authorized data subject or operator, with explicit confirmation and, according to the risk, reauthentication before the action is completed | Common to STPA   |
| CTL-STR-10   | Produce evidence of receipt, processing, and response for the critical transactions, including consents, rights requests, operational commands, and external returns                                            | Common to STPA   |

Table B.3: STRIDE threat records generated by the TMT.

| ID  | Flow | Category               | TMT record                                                         | Decision   | Group       | Hazards       |
|-----|------|------------------------|--------------------------------------------------------------------|------------|-------------|---------------|
| 22  | F9   | Spoofing               | Spoofing of Destination Data Store Database                        | Applicable | CT-STR-06   | H-2           |
| 23  | F9   | Denial of Service      | Potential Excessive Resource Consumption for Backend or Database   | Applicable | CT-STR-04   | H-2, H-7      |
| 292 | F11  | Spoofing               | Spoofing of Destination Data Store Logs/Audit                      | Applicable | CT-STR-05.A | H-2, H-6      |
| 293 | F11  | Denial of Service      | Potential Excessive Resource Consumption for Backend or Logs/Audit | Applicable | CT-STR-05.C | H-2, H-6      |
| 331 | F9   | Tampering              | The Database Data Store Could Be Corrupted                         | Applicable | CT-STR-06   | H-2, H-3      |
| 332 | F9   | Repudiation            | Data Store Denies Database Potentially Writing Data                | Applicable | CT-STR-06   | H-6           |
| 333 | F9   | Information Disclosure | Data Flow Sniffing                                                 | Applicable | CT-STR-06   | H-2           |
| 334 | F9   | Information Disclosure | Weak Credential Transit                                            | Applicable | CT-STR-06   | H-2           |
| 335 | F9   | Denial of Service      | Data Flow Write Is Potentially Interrupted                         | Applicable | CT-STR-04   | H-2, H-3      |
| 336 | F9   | Denial of Service      | Data Store Inaccessible                                            | Applicable | CT-STR-06   | H-2, H-3, H-4 |
| 345 | F11  | Tampering              | The Logs/Audit Data Store Could Be Corrupted                       | Applicable | CT-STR-05.A | H-6           |
| 346 | F11  | Repudiation            | Data Store Denies Logs/Audit Potentially Writing Data              | Applicable | CT-STR-05.A | H-6           |
| 347 | F11  | Information Disclosure | Data Flow Sniffing                                                 | Applicable | CT-STR-05.B | H-2           |
| 348 | F11  | Information Disclosure | Weak Credential Transit                                            | Applicable | CT-STR-05.B | H-2           |

*Continues on the next page*

Table B.3 (continued)

| ID  | Flow | Category               | TMT record                                                                            | Decision              | Group       | Hazards       |
|-----|------|------------------------|---------------------------------------------------------------------------------------|-----------------------|-------------|---------------|
| 349 | F11  | Denial of Service      | Data Flow Audit Log Is Potentially Interrupted                                        | Applicable            | CT-STR-05.C | H-2, H-6      |
| 350 | F11  | Denial of Service      | Data Store Inaccessible                                                               | Applicable            | CT-STR-05.C | H-2, H-6      |
| 352 | F3   | Tampering              | Smartphone (App) Process Memory Tampered                                              | Not applicable (NA-2) | none        | none          |
| 353 | F3   | Repudiation            | Potential Data Repudiation by API                                                     | Applicable            | CT-STR-10   | H-4, H-6      |
| 354 | F3   | Denial of Service      | Potential Process Crash or Stop for API                                               | Applicable            | CT-STR-04   | H-7, H-4      |
| 355 | F3   | Denial of Service      | Data Flow App Request Is Potentially Interrupted                                      | Applicable            | CT-STR-04   | H-7, H-4      |
| 356 | F3   | Elevation of Privilege | Elevation Using Impersonation                                                         | Not applicable (NA-3) | none        | none          |
| 357 | F3   | Elevation of Privilege | API May be Subject to Elevation of Privilege Using Remote Code Execution              | Applicable            | CT-STR-08   | H-2           |
| 358 | F3   | Elevation of Privilege | Elevation by Changing the Execution Flow in API                                       | Applicable            | CT-STR-08   | H-2, H-5      |
| 360 | F4   | Tampering              | API Process Memory Tampered                                                           | Not applicable (NA-2) | none        | none          |
| 361 | F4   | Repudiation            | Potential Data Repudiation by Smartphone (App)                                        | Applicable            | CT-STR-10   | H-4, H-6      |
| 362 | F4   | Denial of Service      | Potential Process Crash or Stop for Smartphone (App)                                  | Applicable            | CT-STR-04   | H-7, H-4      |
| 363 | F4   | Denial of Service      | Data Flow App Response Is Potentially Interrupted                                     | Applicable            | CT-STR-04   | H-7, H-4      |
| 364 | F4   | Elevation of Privilege | Elevation Using Impersonation                                                         | Not applicable (NA-3) | none        | none          |
| 365 | F4   | Elevation of Privilege | Smartphone (App) May be Subject to Elevation of Privilege Using Remote Code Execution | Applicable            | CT-STR-08   | H-2           |
| 366 | F4   | Elevation of Privilege | Elevation by Changing the Execution Flow in Smartphone (App)                          | Applicable            | CT-STR-08   | H-2, H-5      |
| 377 | F7   | Elevation of Privilege | Elevation Using Impersonation                                                         | Applicable            | CT-STR-08   | H-2           |
| 378 | F8   | Tampering              | Backend Process Memory Tampered                                                       | Not applicable (NA-2) | none        | none          |
| 379 | F8   | Elevation of Privilege | Elevation Using Impersonation                                                         | Applicable            | CT-STR-08   | H-2           |
| 380 | F10  | Spoofing               | Spoofing the Backend Process                                                          | Applicable            | CT-STR-06   | H-2           |
| 381 | F10  | Spoofing               | Spoofing of Source Data Store Database                                                | Applicable            | CT-STR-06   | H-2, H-3      |
| 382 | F10  | Repudiation            | Potential Data Repudiation by Backend                                                 | Applicable            | CT-STR-10   | H-6           |
| 383 | F10  | Information Disclosure | Weak Access Control for a Resource                                                    | Applicable            | CT-STR-06   | H-2           |
| 384 | F10  | Denial of Service      | Potential Process Crash or Stop for Backend                                           | Applicable            | CT-STR-04   | H-2, H-7      |
| 385 | F10  | Denial of Service      | Data Flow Read Is Potentially Interrupted                                             | Applicable            | CT-STR-04   | H-2, H-7      |
| 386 | F10  | Denial of Service      | Data Store Inaccessible                                                               | Applicable            | CT-STR-06   | H-2, H-3, H-4 |
| 387 | F10  | Elevation of Privilege | Backend May be Subject to Elevation of Privilege Using Remote Code Execution          | Applicable            | CT-STR-06   | H-2           |
| 388 | F10  | Elevation of Privilege | Elevation by Changing the Execution Flow in Backend                                   | Applicable            | CT-STR-08   | H-2, H-5      |
| 390 | F15  | Tampering              | Backend Process Memory Tampered                                                       | Not applicable (NA-2) | none        | none          |

*Continues on the next page*

Table B.3 (continued)

| ID  | Flow | Category               | TMT record                                                                          | Decision              | Group       | Hazards       |
|-----|------|------------------------|-------------------------------------------------------------------------------------|-----------------------|-------------|---------------|
| 391 | F15  | Repudiation            | Potential Data Repudiation by Browser Client                                        | Applicable            | CT-STR-10   | H-6           |
| 392 | F15  | Denial of Service      | Potential Process Crash or Stop for Browser Client                                  | Applicable            | CT-STR-04   | H-2, H-7      |
| 393 | F15  | Denial of Service      | Data Flow Admin Response Is Potentially Interrupted                                 | Applicable            | CT-STR-04   | H-2, H-7      |
| 394 | F15  | Elevation of Privilege | Elevation Using Impersonation                                                       | Not applicable (NA-3) | none        | none          |
| 395 | F15  | Elevation of Privilege | Browser Client May be Subject to Elevation of Privilege Using Remote Code Execution | Applicable            | CT-STR-08   | H-2           |
| 396 | F15  | Elevation of Privilege | Elevation by Changing the Execution Flow in Browser Client                          | Applicable            | CT-STR-08   | H-2           |
| 398 | F14  | Repudiation            | Potential Data Repudiation by Backend                                               | Applicable            | CT-STR-10   | H-6, H-4      |
| 399 | F14  | Denial of Service      | Potential Process Crash or Stop for Backend                                         | Applicable            | CT-STR-04   | H-2, H-4, H-7 |
| 400 | F14  | Denial of Service      | Data Flow Admin Request Is Potentially Interrupted                                  | Applicable            | CT-STR-04   | H-4, H-7      |
| 401 | F14  | Elevation of Privilege | Elevation Using Impersonation                                                       | Applicable            | CT-STR-08   | H-2           |
| 402 | F14  | Elevation of Privilege | Backend May be Subject to Elevation of Privilege Using Remote Code Execution        | Applicable            | CT-STR-08   | H-2           |
| 403 | F14  | Elevation of Privilege | Elevation by Changing the Execution Flow in Backend                                 | Applicable            | CT-STR-08   | H-2           |
| 404 | F3   | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2, H-1      |
| 405 | F3   | Tampering              | Replay Attacks                                                                      | Applicable            | CT-STR-02   | H-1, H-2      |
| 406 | F3   | Tampering              | Collision Attacks                                                                   | Applicable            | CT-STR-02   | H-2           |
| 407 | F4   | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2, H-1      |
| 408 | F7   | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2           |
| 409 | F4   | Tampering              | Replay Attacks                                                                      | Applicable            | CT-STR-02   | H-1, H-2      |
| 410 | F4   | Tampering              | Collision Attacks                                                                   | Applicable            | CT-STR-02   | H-2           |
| 411 | F7   | Tampering              | Replay Attacks                                                                      | Applicable            | CT-STR-02   | H-2           |
| 412 | F7   | Tampering              | Collision Attacks                                                                   | Applicable            | CT-STR-02   | H-2           |
| 413 | F8   | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2           |
| 414 | F9   | Information Disclosure | Authorization Bypass                                                                | Applicable            | CT-STR-06   | H-2           |
| 415 | F11  | Information Disclosure | Authorization Bypass                                                                | Applicable            | CT-STR-05.B | H-2, H-6      |
| 416 | F15  | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2, H-6      |
| 417 | F8   | Tampering              | Replay Attacks                                                                      | Applicable            | CT-STR-02   | H-2           |
| 418 | F8   | Tampering              | Collision Attacks                                                                   | Applicable            | CT-STR-02   | H-2           |
| 419 | F15  | Tampering              | Replay Attacks                                                                      | Applicable            | CT-STR-02   | H-6           |
| 420 | F15  | Tampering              | Collision Attacks                                                                   | Applicable            | CT-STR-02   | H-2           |
| 421 | F14  | Information Disclosure | Weak Authentication Scheme                                                          | Applicable            | CT-STR-01   | H-2, H-6      |
| 422 | F11  | Tampering              | Risks from Logging                                                                  | Applicable            | CT-STR-05.A | H-2, H-6      |
| 423 | F11  | Repudiation            | Lower Trusted Subject Updates Logs                                                  | Applicable            | CT-STR-05.A | H-6           |
| 424 | F11  | Repudiation            | Data Logs from an Unknown Source                                                    | Applicable            | CT-STR-05.A | H-6           |
| 425 | F11  | Repudiation            | Insufficient Auditing                                                               | Applicable            | CT-STR-05.A | H-6           |
| 426 | F11  | Repudiation            | Potential Weak Protections for Audit Data                                           | Applicable            | CT-STR-05.A | H-6           |

*Continues on the next page*

Table B.3 (continued)

| ID  | Flow | Category               | TMT record                                                               | Decision   | Group     | Hazards       |
|-----|------|------------------------|--------------------------------------------------------------------------|------------|-----------|---------------|
| 427 | F3   | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 428 | F4   | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 429 | F7   | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 430 | F8   | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 431 | F14  | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 432 | F15  | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-03 | H-2           |
| 435 | F5   | Spoofing               | Spoofing of the SEFD External Destination Entity                         | Applicable | CT-STR-07 | H-2, H-7      |
| 436 | F5   | Repudiation            | External Entity SEFD Potentially Denies Receiving Data                   | Applicable | CT-STR-07 | H-6, H-7      |
| 437 | F5   | Denial of Service      | Data Flow SEFD Request Is Potentially Interrupted                        | Applicable | CT-STR-04 | H-7           |
| 438 | F6   | Tampering              | JavaScript Object Notation Processing                                    | Applicable | CT-STR-07 | H-2, H-7      |
| 439 | F6   | Repudiation            | Potential Data Repudiation by API                                        | Applicable | CT-STR-10 | H-6           |
| 440 | F6   | Denial of Service      | Potential Process Crash or Stop for API                                  | Applicable | CT-STR-04 | H-7           |
| 441 | F6   | Denial of Service      | Data Flow SEFD Response Is Potentially Interrupted                       | Applicable | CT-STR-04 | H-7           |
| 442 | F6   | Elevation of Privilege | Elevation Using Impersonation                                            | Applicable | CT-STR-07 | H-2, H-7      |
| 443 | F6   | Elevation of Privilege | API May be Subject to Elevation of Privilege Using Remote Code Execution | Applicable | CT-STR-07 | H-2, H-7      |
| 444 | F6   | Elevation of Privilege | Elevation by Changing the Execution Flow in API                          | Applicable | CT-STR-07 | H-2, H-5, H-7 |
| 445 | F1   | Spoofing               | Spoofing the Tourist External Entity                                     | Applicable | CT-STR-09 | H-1, H-2      |
| 446 | F1   | Elevation of Privilege | Elevation Using Impersonation                                            | Applicable | CT-STR-09 | H-1, H-2      |
| 447 | F12  | Spoofing               | Spoofing the Operations Team External Entity                             | Applicable | CT-STR-09 | H-2, H-6      |
| 448 | F12  | Elevation of Privilege | Elevation Using Impersonation                                            | Applicable | CT-STR-09 | H-2, H-6      |

## Catalog C

# LINDDUN PRO threat groups, threats, and controls of Step 7

This catalog registers the complete results of the LINDDUN PRO analysis of Step 7, presented in Section 6.3 of the dissertation. Table C.1 presents the 24 threat groups with their threat family, the predominant category, the flows, the number of threats consolidated in each group, the number of derived controls, and the hazards. Table C.2 presents, for each of the 107 threats, the DFD flow, the interaction position, the LINDDUN category, and the group in which the threat was consolidated. Table C.3 presents, for each of the 71 controls, the group or groups from which it was derived, its short name, its nature, its relation to STPA, and the hazards. The statements of the controls and the expected evidence are registered in the instrument of the analysis and in the mapping of Chapter 7 of the dissertation. In the names of the groups and of the controls, operator designates a member of the Operations Team, the staff of the controller, and not the data processor of the law, which A-8 leaves outside the scope of the analysis.

Table C.1: LINDDUN PRO threat groups of Step 7, with the flows, the number of threats and controls, and the hazards.

| Group     | Threat family (pre-dominant category)                                                    | Flows                                 | Threats | Controls | Hazards            |
|-----------|------------------------------------------------------------------------------------------|---------------------------------------|---------|----------|--------------------|
| CT-LIN-01 | Persistent identifiers and longitudinal linking (Linking)                                | F1, F3, F4, F5, F7, F9, F11, F12, F14 | 13      | 4        | H-1, H-2, H-5, H-6 |
| CT-LIN-02 | Direct identification and singling out of the data subject (Identifying)                 | F1, F3, F5, F7, F9                    | 8       | 3        | H-1, H-2, H-5, H-6 |
| CT-LIN-03 | Collection, requests, and responses with excessive data (Data Disclosure)                | F1, F3, F4, F5, F7, F8, F9, F14       | 8       | 3        | H-1, H-3, H-6      |
| CT-LIN-04 | Transparency and intervenability of the data subject (Unawareness and Unintervenability) | F1, F2                                | 4       | 3        | H-1, H-4, H-5, H-7 |
| CT-LIN-05 | Local exposure in the interface and device of the data subject (Data Disclosure)         | F1, F2                                | 3       | 2        | H-1, H-2, H-3      |

*Continues on the next page*

Table C.1 (continued)

| Group     | Threat family (pre-dominant category)                                             | Flows                   | Threats | Controls | Hazards                 |
|-----------|-----------------------------------------------------------------------------------|-------------------------|---------|----------|-------------------------|
| CT-LIN-06 | Local persistence, cache, and residual data in the clients (Linking)              | F1, F12, F14            | 4       | 3        | H-2, H-3, H-6           |
| CT-LIN-07 | Inferences, profiling, and revealing responses (Identifying)                      | F2, F4, F8              | 4       | 3        | H-1, H-5, H-7           |
| CT-LIN-08 | Excessive non-repudiation and disproportionate accountability (Non-repudiation)   | F1, F2, F3, F7, F9, F12 | 6       | 2        | H-1, H-2, H-6           |
| CT-LIN-09 | Detectability and meta-data of use and communication (Detecting)                  | F1, F3, F5, F10, F11    | 5       | 4        | H-1, H-2, H-5           |
| CT-LIN-10 | Sharing with the third-party SEFD and external governance (Non-compliance)        | F5                      | 4       | 3        | H-1, H-3, H-6, H-7      |
| CT-LIN-11 | SEFD responses combined with internal data (Linking)                              | F6                      | 4       | 2        | H-1, H-5, H-6, H-7      |
| CT-LIN-12 | Internal propagation and secondary use in the API and Backend (Non-compliance)    | F3, F7, F8              | 6       | 3        | H-1, H-3, H-6           |
| CT-LIN-13 | Observability, tracing, and technical exposure (Data Disclosure)                  | F3, F5, F7, F11, F14    | 7       | 5        | H-2, H-6                |
| CT-LIN-14 | Architectural linkability and re-identification in persistence (Linking)          | F3, F9, F10             | 3       | 2        | H-2, H-3, H-5, H-6      |
| CT-LIN-15 | Life cycle, retention, deletion, and purpose of the data (Non-compliance)         | F9, F11                 | 5       | 5        | H-1, H-3, H-6           |
| CT-LIN-16 | Excessive reads and downstream reuse of persisted data (Data Disclosure)          | F10                     | 2       | 2        | H-1, H-2, H-3, H-4, H-6 |
| CT-LIN-17 | Logs as personal data (Data Disclosure)                                           | F11                     | 1       | 3        | H-2, H-3, H-6           |
| CT-LIN-18 | Excessive surveillance and traceability of the operator (Non-repudiation)         | F12, F14                | 4       | 2        | H-1, H-2, H-6           |
| CT-LIN-19 | Multi-subject exposure in dashboards and operational interfaces (Data Disclosure) | F13, F15                | 5       | 3        | H-2, H-5, H-6           |
| CT-LIN-20 | Shadow data, parallel records, and insider threat (Data Disclosure)               | F13                     | 2       | 3        | H-1, H-2, H-6           |

Continues on the next page

Table C.1 (continued)

| Group     | Threat family (pre-dominant category)                                                     | Flows              | Threats | Controls | Hazards                 |
|-----------|-------------------------------------------------------------------------------------------|--------------------|---------|----------|-------------------------|
| CT-LIN-21 | Irreversible administrative operations without proportional confirmation (Non-compliance) | F14                | 1       | 2        | H-2, H-3, H-4, H-6      |
| CT-LIN-22 | Absent just-in-time verification for actions on personal data (Non-compliance)            | F10, F13, F14, F15 | 4       | 7        | H-1, H-2, H-3, H-4, H-6 |
| CT-LIN-23 | Absent governance meta-data in persistence (Non-compliance)                               | F9, F11            | 2       | 5        | H-1, H-3, H-6           |
| CT-LIN-24 | Proportionality of linking and non-repudiation (Linking and Non-repudiation)              | F11, F15           | 2       | 6        | H-1, H-2, H-6           |

Table C.2: LINDDUN PRO threats elicited in Step 7.

| Threat     | Flow | Position    | LINDDUN PRO category              | Group     |
|------------|------|-------------|-----------------------------------|-----------|
| AM-LIN-001 | F1   | Source      | Linking                           | CT-LIN-01 |
| AM-LIN-002 | F1   | Source      | Identifying                       | CT-LIN-02 |
| AM-LIN-003 | F1   | Source      | Unawareness and Unintervenability | CT-LIN-04 |
| AM-LIN-004 | F1   | Source      | Unawareness and Unintervenability | CT-LIN-04 |
| AM-LIN-005 | F1   | Destination | Data Disclosure                   | CT-LIN-03 |
| AM-LIN-006 | F1   | Data flow   | Data Disclosure                   | CT-LIN-05 |
| AM-LIN-007 | F1   | Data flow   | Detecting                         | CT-LIN-09 |
| AM-LIN-008 | F1   | Destination | Linking                           | CT-LIN-06 |
| AM-LIN-009 | F1   | Destination | Identifying                       | CT-LIN-02 |
| AM-LIN-010 | F1   | Destination | Non-repudiation                   | CT-LIN-08 |
| AM-LIN-011 | F1   | Destination | Data Disclosure                   | CT-LIN-05 |
| AM-LIN-012 | F1   | Destination | Non-compliance                    | CT-LIN-06 |
| AM-LIN-013 | F2   | Source      | Identifying                       | CT-LIN-07 |
| AM-LIN-014 | F2   | Source      | Non-repudiation                   | CT-LIN-08 |
| AM-LIN-015 | F2   | Data flow   | Data Disclosure                   | CT-LIN-05 |
| AM-LIN-016 | F2   | Destination | Unawareness and Unintervenability | CT-LIN-04 |
| AM-LIN-017 | F2   | Destination | Unawareness and Unintervenability | CT-LIN-04 |
| AM-LIN-018 | F3   | Source      | Linking                           | CT-LIN-01 |
| AM-LIN-019 | F3   | Source      | Identifying                       | CT-LIN-02 |
| AM-LIN-020 | F3   | Source      | Data Disclosure                   | CT-LIN-03 |
| AM-LIN-021 | F3   | Data flow   | Linking                           | CT-LIN-01 |
| AM-LIN-022 | F3   | Data flow   | Non-repudiation                   | CT-LIN-08 |
| AM-LIN-023 | F3   | Data flow   | Detecting                         | CT-LIN-09 |
| AM-LIN-024 | F3   | Data flow   | Data Disclosure                   | CT-LIN-13 |
| AM-LIN-025 | F3   | Destination | Linking                           | CT-LIN-14 |
| AM-LIN-026 | F3   | Destination | Data Disclosure                   | CT-LIN-12 |
| AM-LIN-027 | F3   | Destination | Non-compliance                    | CT-LIN-12 |
| AM-LIN-028 | F4   | Source      | Identifying                       | CT-LIN-07 |
| AM-LIN-029 | F4   | Source      | Data Disclosure                   | CT-LIN-03 |
| AM-LIN-030 | F4   | Source      | Linking                           | CT-LIN-01 |
| AM-LIN-031 | F5   | Source      | Linking                           | CT-LIN-01 |
| AM-LIN-032 | F5   | Source      | Identifying                       | CT-LIN-02 |
| AM-LIN-033 | F5   | Source      | Data Disclosure                   | CT-LIN-03 |
| AM-LIN-034 | F5   | Source      | Non-compliance                    | CT-LIN-10 |
| AM-LIN-035 | F5   | Data flow   | Linking                           | CT-LIN-13 |
| AM-LIN-036 | F5   | Data flow   | Detecting                         | CT-LIN-09 |
| AM-LIN-037 | F5   | Data flow   | Data Disclosure                   | CT-LIN-13 |

*Continues on the next page*

Table C.2 (continued)

| Threat     | Flow | Position    | LINDDUN PRO category | Group     |
|------------|------|-------------|----------------------|-----------|
| AM-LIN-038 | F5   | Destination | Linking              | CT-LIN-10 |
| AM-LIN-039 | F5   | Destination | Data Disclosure      | CT-LIN-10 |
| AM-LIN-040 | F5   | Destination | Non-compliance       | CT-LIN-10 |
| AM-LIN-041 | F6   | Source      | Data Disclosure      | CT-LIN-11 |
| AM-LIN-042 | F6   | Destination | Linking              | CT-LIN-11 |
| AM-LIN-043 | F6   | Destination | Identifying          | CT-LIN-11 |
| AM-LIN-044 | F6   | Destination | Non-compliance       | CT-LIN-11 |
| AM-LIN-045 | F7   | Source      | Linking              | CT-LIN-01 |
| AM-LIN-046 | F7   | Source      | Identifying          | CT-LIN-02 |
| AM-LIN-047 | F7   | Source      | Data Disclosure      | CT-LIN-03 |
| AM-LIN-048 | F7   | Source      | Non-compliance       | CT-LIN-12 |
| AM-LIN-049 | F7   | Data flow   | Linking              | CT-LIN-01 |
| AM-LIN-050 | F7   | Data flow   | Non-repudiation      | CT-LIN-08 |
| AM-LIN-051 | F7   | Data flow   | Data Disclosure      | CT-LIN-13 |
| AM-LIN-052 | F7   | Destination | Linking              | CT-LIN-12 |
| AM-LIN-053 | F7   | Destination | Data Disclosure      | CT-LIN-12 |
| AM-LIN-054 | F8   | Source      | Identifying          | CT-LIN-07 |
| AM-LIN-055 | F8   | Source      | Data Disclosure      | CT-LIN-03 |
| AM-LIN-056 | F8   | Destination | Non-compliance       | CT-LIN-12 |
| AM-LIN-057 | F7   | Destination | Identifying          | CT-LIN-02 |
| AM-LIN-058 | F8   | Data flow   | Detecting            | CT-LIN-07 |
| AM-LIN-059 | F9   | Source      | Linking              | CT-LIN-01 |
| AM-LIN-060 | F9   | Source      | Identifying          | CT-LIN-02 |
| AM-LIN-061 | F9   | Source      | Data Disclosure      | CT-LIN-03 |
| AM-LIN-062 | F9   | Destination | Linking              | CT-LIN-14 |
| AM-LIN-063 | F9   | Destination | Identifying          | CT-LIN-02 |
| AM-LIN-064 | F9   | Destination | Non-repudiation      | CT-LIN-08 |
| AM-LIN-065 | F9   | Destination | Data Disclosure      | CT-LIN-15 |
| AM-LIN-066 | F9   | Destination | Non-compliance       | CT-LIN-15 |
| AM-LIN-067 | F9   | Destination | Non-compliance       | CT-LIN-15 |
| AM-LIN-068 | F10  | Source      | Linking              | CT-LIN-14 |
| AM-LIN-069 | F10  | Source      | Data Disclosure      | CT-LIN-16 |
| AM-LIN-070 | F10  | Destination | Non-compliance       | CT-LIN-16 |
| AM-LIN-071 | F9   | Source      | Non-compliance       | CT-LIN-23 |
| AM-LIN-072 | F10  | Source      | Detecting            | CT-LIN-09 |
| AM-LIN-073 | F10  | Destination | Non-compliance       | CT-LIN-22 |
| AM-LIN-074 | F11  | Source      | Linking              | CT-LIN-01 |
| AM-LIN-075 | F11  | Source      | Data Disclosure      | CT-LIN-13 |
| AM-LIN-076 | F11  | Source      | Non-compliance       | CT-LIN-23 |
| AM-LIN-077 | F11  | Data flow   | Linking              | CT-LIN-01 |
| AM-LIN-078 | F11  | Data flow   | Data Disclosure      | CT-LIN-13 |
| AM-LIN-079 | F11  | Destination | Linking              | CT-LIN-01 |
| AM-LIN-080 | F11  | Destination | Non-repudiation      | CT-LIN-24 |
| AM-LIN-081 | F11  | Data flow   | Detecting            | CT-LIN-09 |
| AM-LIN-082 | F11  | Destination | Data Disclosure      | CT-LIN-17 |
| AM-LIN-083 | F11  | Destination | Non-compliance       | CT-LIN-15 |
| AM-LIN-084 | F11  | Destination | Non-compliance       | CT-LIN-15 |
| AM-LIN-085 | F12  | Source      | Linking              | CT-LIN-18 |
| AM-LIN-086 | F12  | Source      | Non-repudiation      | CT-LIN-08 |
| AM-LIN-087 | F12  | Source      | Data Disclosure      | CT-LIN-18 |
| AM-LIN-088 | F12  | Destination | Non-compliance       | CT-LIN-18 |
| AM-LIN-089 | F12  | Data flow   | Linking              | CT-LIN-01 |
| AM-LIN-090 | F12  | Destination | Data Disclosure      | CT-LIN-06 |
| AM-LIN-091 | F13  | Source      | Linking              | CT-LIN-19 |
| AM-LIN-092 | F13  | Source      | Identifying          | CT-LIN-19 |
| AM-LIN-093 | F13  | Source      | Data Disclosure      | CT-LIN-19 |
| AM-LIN-094 | F13  | Destination | Linking              | CT-LIN-20 |
| AM-LIN-095 | F13  | Destination | Data Disclosure      | CT-LIN-20 |
| AM-LIN-096 | F13  | Destination | Non-compliance       | CT-LIN-22 |
| AM-LIN-097 | F14  | Source      | Data Disclosure      | CT-LIN-06 |
| AM-LIN-098 | F14  | Data flow   | Linking              | CT-LIN-01 |
| AM-LIN-099 | F14  | Data flow   | Data Disclosure      | CT-LIN-13 |

*Continues on the next page*

Table C.2 (continued)

| Threat     | Flow | Position    | LINDDUN PRO category | Group     |
|------------|------|-------------|----------------------|-----------|
| AM-LIN-100 | F14  | Destination | Data Disclosure      | CT-LIN-03 |
| AM-LIN-101 | F14  | Destination | Non-compliance       | CT-LIN-22 |
| AM-LIN-102 | F14  | Destination | Non-compliance       | CT-LIN-21 |
| AM-LIN-103 | F14  | Destination | Non-repudiation      | CT-LIN-18 |
| AM-LIN-104 | F15  | Source      | Linking              | CT-LIN-24 |
| AM-LIN-105 | F15  | Source      | Identifying          | CT-LIN-19 |
| AM-LIN-106 | F15  | Source      | Data Disclosure      | CT-LIN-19 |
| AM-LIN-107 | F15  | Source      | Non-compliance       | CT-LIN-22 |

Table C.3: LINDDUN PRO controls derived in Step 7.

| Control     | Derived from | Short name                                           | Nature    | Relation to STPA | Hazards            |
|-------------|--------------|------------------------------------------------------|-----------|------------------|--------------------|
| CTL-LIN-001 | CT-LIN-01    | Rotating and scoped identifiers                      | Technical | Additional       | H-1, H-2, H-5, H-6 |
| CTL-LIN-002 | CT-LIN-01    | Separation of correlation keys                       | Technical | Additional       | H-1, H-2, H-5, H-6 |
| CTL-LIN-003 | CT-LIN-02    | Identification on demand                             | Hybrid    | Additional       | H-1, H-2, H-5, H-6 |
| CTL-LIN-004 | CT-LIN-02    | Reduction of identifying attributes                  | Technical | Additional       | H-1, H-2, H-5, H-6 |
| CTL-LIN-005 | CT-LIN-03    | Minimum data contracts per purpose                   | Hybrid    | Common to STPA   | H-1, H-3, H-6      |
| CTL-LIN-006 | CT-LIN-03    | Response filtering by context                        | Technical | Common to STPA   | H-1, H-3, H-6      |
| CTL-LIN-007 | CT-LIN-03    | Blocking of overcollection                           | Hybrid    | Common to STPA   | H-1, H-3, H-6      |
| CTL-LIN-008 | CT-LIN-04    | Contextual data privacy notices                      | Technical | Common to STPA   | H-1, H-4, H-5, H-7 |
| CTL-LIN-009 | CT-LIN-04    | Preferences and rights center                        | Technical | Common to STPA   | H-1, H-4, H-5, H-7 |
| CTL-LIN-010 | CT-LIN-04    | Transparency of the advisory personalization         | Hybrid    | Common to STPA   | H-1, H-4, H-5, H-7 |
| CTL-LIN-011 | CT-LIN-05    | Local interface with data privacy by default         | Technical | Additional       | H-1, H-2, H-3      |
| CTL-LIN-012 | CT-LIN-05    | Contextual masking on the device                     | Technical | Additional       | H-1, H-2, H-3      |
| CTL-LIN-013 | CT-LIN-06    | Control of cache and local storage                   | Technical | Additional       | H-2, H-3, H-6      |
| CTL-LIN-014 | CT-LIN-06    | Removal of local residual data                       | Technical | Additional       | H-2, H-3, H-6      |
| CTL-LIN-015 | CT-LIN-07    | Minimization of inferences                           | Hybrid    | Common to STPA   | H-1, H-5, H-7      |
| CTL-LIN-016 | CT-LIN-07    | Control of the data subject over the personalization | Technical | Common to STPA   | H-1, H-5, H-7      |
| CTL-LIN-017 | CT-LIN-07    | Contextual explanation of the recommendations        | Hybrid    | Common to STPA   | H-1, H-5, H-7      |
| CTL-LIN-018 | CT-LIN-08    | Proportionality of non-repudiation                   | Hybrid    | Additional       | H-1, H-2, H-6      |
| CTL-LIN-019 | CT-LIN-08    | Separation between audit and profiling               | Hybrid    | Additional       | H-1, H-2, H-6      |
| CTL-LIN-020 | CT-LIN-09    | Minimization of communication metadata               | Technical | Additional       | H-1, H-2, H-5      |
| CTL-LIN-021 | CT-LIN-09    | Aggregation and smoothing of usage signals           | Technical | Additional       | H-1, H-2, H-5      |
| CTL-LIN-022 | CT-LIN-10    | Blocking of personal data in the SEFD integration    | Technical | Additional       | H-1, H-3, H-6, H-7 |

Continues on the next page

Table C.3 (continued)

| Control     | Derived from | Short name                                                                           | Nature         | Relation to STPA | Hazards                 |
|-------------|--------------|--------------------------------------------------------------------------------------|----------------|------------------|-------------------------|
| CTL-LIN-023 | CT-LIN-10    | Contractual and technical governance of the SEFD without processing of personal data | Organizational | Additional       | H-1, H-3, H-6, H-7      |
| CTL-LIN-024 | CT-LIN-10    | Server-to-server mediation of the SEFD query                                         | Technical      | Additional       | H-1, H-3, H-6, H-7      |
| CTL-LIN-025 | CT-LIN-11    | Filtering of the SEFD responses                                                      | Technical      | Additional       | H-1, H-5, H-6, H-7      |
| CTL-LIN-026 | CT-LIN-11    | Separation of external context and internal profile                                  | Technical      | Additional       | H-1, H-5, H-6, H-7      |
| CTL-LIN-027 | CT-LIN-12    | Internal routing by purpose                                                          | Technical      | Additional       | H-1, H-3, H-6           |
| CTL-LIN-028 | CT-LIN-12    | Control of internal secondary use                                                    | Hybrid         | Additional       | H-1, H-3, H-6           |
| CTL-LIN-029 | CT-LIN-12    | Internal data lineage                                                                | Technical      | Additional       | H-1, H-3, H-6           |
| CTL-LIN-030 | CT-LIN-13    | Telemetry with data privacy safeguards                                               | Technical      | Additional       | H-2, H-6                |
| CTL-LIN-031 | CT-LIN-13    | Access control to observability                                                      | Technical      | Additional       | H-2, H-6                |
| CTL-LIN-032 | CT-LIN-13    | Short retention for detailed telemetry                                               | Technical      | Additional       | H-2, H-6                |
| CTL-LIN-033 | CT-LIN-14    | Architectural separation of data domains                                             | Technical      | Additional       | H-2, H-3, H-5, H-6      |
| CTL-LIN-034 | CT-LIN-14    | Aggregated analytical views                                                          | Technical      | Additional       | H-2, H-3, H-5, H-6      |
| CTL-LIN-035 | CT-LIN-15    | Life-cycle policies per data class                                                   | Hybrid         | Common to STPA   | H-1, H-3, H-6           |
| CTL-LIN-036 | CT-LIN-15    | Propagation of corrections and deletions                                             | Technical      | Common to STPA   | H-1, H-3, H-6           |
| CTL-LIN-037 | CT-LIN-15    | Management of exceptional retention                                                  | Hybrid         | Additional       | H-1, H-3, H-6           |
| CTL-LIN-038 | CT-LIN-16    | Just-enough queries                                                                  | Technical      | Additional       | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-039 | CT-LIN-16    | Blocking of downstream reuse                                                         | Technical      | Additional       | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-040 | CT-LIN-17    | Classification of logs as personal data                                              | Organizational | Additional       | H-2, H-3, H-6           |
| CTL-LIN-041 | CT-LIN-17    | Specific safeguards for logs that are personal data                                  | Technical      | Additional       | H-2, H-3, H-6           |
| CTL-LIN-042 | CT-LIN-18    | Proportionality in the monitoring of operators                                       | Organizational | Additional       | H-1, H-2, H-6           |
| CTL-LIN-043 | CT-LIN-18    | Separation between audit and workplace surveillance                                  | Hybrid         | Additional       | H-1, H-2, H-6           |
| CTL-LIN-044 | CT-LIN-19    | Dashboards with multi-subject minimization                                           | Technical      | Additional       | H-2, H-5, H-6           |
| CTL-LIN-045 | CT-LIN-19    | Controls against improper export                                                     | Technical      | Additional       | H-2, H-5, H-6           |
| CTL-LIN-046 | CT-LIN-19    | Segmented visualization by need                                                      | Technical      | Additional       | H-2, H-5, H-6           |
| CTL-LIN-047 | CT-LIN-20    | Controlled environment for operational annotations                                   | Technical      | Additional       | H-1, H-2, H-6           |
| CTL-LIN-048 | CT-LIN-20    | Prevention of internal privilege abuse                                               | Hybrid         | Additional       | H-1, H-2, H-6           |
| CTL-LIN-049 | CT-LIN-20    | Governance of internal copying and sharing                                           | Hybrid         | Additional       | H-1, H-2, H-6           |

Continues on the next page

Table C.3 (continued)

| Control     | Derived from                               | Short name                                                                                    | Nature         | Relation to STPA | Hazards                 |
|-------------|--------------------------------------------|-----------------------------------------------------------------------------------------------|----------------|------------------|-------------------------|
| CTL-LIN-050 | CT-LIN-21                                  | Proportional confirmation for irreversible actions                                            | Technical      | Additional       | H-2, H-3, H-4, H-6      |
| CTL-LIN-051 | CT-LIN-21                                  | Reversibility and reconciliation                                                              | Technical      | Additional       | H-2, H-3, H-4, H-6      |
| CTL-LIN-052 | CT-LIN-22                                  | Just-in-time verification of authorization                                                    | Technical      | Common to STPA   | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-053 | CT-LIN-22                                  | Step-up for sensitive actions                                                                 | Technical      | Common to STPA   | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-054 | CT-LIN-22                                  | Denial by outdated context                                                                    | Technical      | Common to STPA   | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-055 | CT-LIN-23                                  | Embedded governance metadata                                                                  | Technical      | Additional       | H-1, H-3, H-6           |
| CTL-LIN-056 | CT-LIN-23                                  | Metadata-driven policy engine                                                                 | Technical      | Additional       | H-1, H-3, H-6           |
| CTL-LIN-057 | CT-LIN-23                                  | Validation of metadata completeness                                                           | Technical      | Additional       | H-1, H-3, H-6           |
| CTL-LIN-058 | CT-LIN-24                                  | Calibration of legitimate correlation and attribution                                         | Hybrid         | Additional       | H-1, H-2, H-6           |
| CTL-LIN-059 | CT-LIN-24                                  | Periodic review of correlation and attribution flows                                          | Organizational | Additional       | H-1, H-2, H-6           |
| CTL-LIN-060 | CT-LIN-24                                  | Specific controls for necessary linking and non-repudiation                                   | Technical      | Additional       | H-1, H-2, H-6           |
| CTL-LIN-061 | CT-LIN-01                                  | Obfuscation of traffic metadata                                                               | Technical      | Additional       | H-1, H-2, H-5, H-6      |
| CTL-LIN-062 | CT-LIN-01                                  | Central catalog of identifiers                                                                | Organizational | Additional       | H-1, H-2, H-5, H-6      |
| CTL-LIN-063 | CT-LIN-02                                  | Resistance to re-identification by combination                                                | Technical      | Additional       | H-1, H-2, H-5, H-6      |
| CTL-LIN-064 | CT-LIN-09                                  | Countermeasures to presence side channels                                                     | Technical      | Additional       | H-1, H-2, H-5           |
| CTL-LIN-065 | CT-LIN-22                                  | Audit trail of the revalidations                                                              | Technical      | Additional       | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-066 | CT-LIN-22                                  | Information to the operator about the LGPD state of the data subject                          | Technical      | Additional       | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-067 | CT-LIN-24                                  | Design justification with consultation of the DPO                                             | Organizational | Additional       | H-1, H-2, H-6           |
| CTL-LIN-068 | CT-LIN-06, CT-LIN-13, CT-LIN-15, CT-LIN-17 | Encryption at rest of personal data                                                           | Technical      | Additional       | H-1, H-2, H-3, H-6      |
| CTL-LIN-069 | CT-LIN-09, CT-LIN-13                       | Reinforced protection of the transport channel                                                | Technical      | Additional       | H-1, H-2, H-5, H-6      |
| CTL-LIN-070 | CT-LIN-15, CT-LIN-22, CT-LIN-23, CT-LIN-24 | Data protection impact report of the controller for high-risk processing and relevant changes | Organizational | Additional       | H-1, H-2, H-3, H-4, H-6 |
| CTL-LIN-071 | CT-LIN-22, CT-LIN-23, CT-LIN-24            | Formal decision of the controller with consultation of the DPO                                | Organizational | Additional       | H-1, H-2, H-3, H-4, H-6 |